IDEATION PHASE

Brainstorm & Idea Prioritization

Date	03 October 2026
Team ID	SWTID-2026-6390
Project Name	Script-Controlled ACL – Restrict Record Access Based on Field Value
Maximum Marks	4 Marks

Brainstorming gives the team an open space to share ideas without judging them early. For this project, the sessions were focused on one question: how can the Institution Details table in ServiceNow be protected so that every user sees and changes only what their role allows? The ideas below cover the branch condition, the ACL script, the bb1–bb4 roles, administrator access and testing.

Step 1: Team Gathering, Collaboration and Problem Selection

Selected problem statement: How can we make sure that a user can read, create, edit or delete Institution Details records only when their role permits it, so that EEE branch records are shown only to authorised users while administrators keep full access?

Stakeholder perspectives considered:

- System administrator – needs full access and wants permissions that are simple to set up and check.
- EEE branch user with the bb1 role – needs to open the Institution Details list and read EEE records.
- User with no matching role – should not be able to see the protected records at all.
- Users with bb2, bb3 or bb4 – need CREATE, WRITE or DELETE access only for the work they are assigned.
- Tester / reviewer – needs a clear way to confirm that every rule works, using impersonation.

Step 2: Brainstorm, Idea Listing and Grouping

Idea Group	Idea	Description
Field-Based Access	Branch = EEE condition	Add the Branch = EEE condition to the READ ACL so that only EEE records match the rule.
Field-Based Access	Check ECE and CSE records	Keep sample ECE and CSE records in the table to prove that other branches are not exposed through the EEE rule.
ACL Script	Script-based READ ACL	Write an advanced ACL script that returns true for administrators and bb1 users and false for everyone else.
Role-Based Permissions	One ACL per operation	Create separate ACLs for READ, CREATE, WRITE and DELETE so that each action can be controlled on its own.
Role-Based Permissions	bb1–bb4 role mapping	Map bb1 to READ, bb2 to CREATE, bb3 to WRITE and bb4 to DELETE so that each role has one clear purpose.
Least Privilege	Minimum roles per user	Give each user only the role they need, for example bb1 alone for a read-only user.
Admin Access	Administrator access check	Log in as an administrator and confirm that EEE, ECE and CSE records are all visible with full operations.
Testing & Validation	Impersonation testing	Impersonate users who hold different single roles and role combinations and compare the results with the expected access.
Testing & Validation	Negative testing	Impersonate a user without bb1 and confirm that the Institution Details records are not shown.
Documentation	Permission matrix and test log	Prepare a role-versus-operation table before configuring, then record each test with its expected and actual result.

Step 3: Idea Prioritization

Each idea was rated using an Importance–Feasibility view. **Importance** shows how much the idea helps security and correct access. **Feasibility** shows how easily it can be done with the existing ACL setup on the Institution Details table.

Idea	Importance	Feasibility	Priority
Branch = EEE condition on READ ACL	High	High	**P1**
One ACL per operation	High	High	**P1**
bb1–bb4 role mapping	High	High	**P1**
Impersonation testing	High	High	**P1**
Negative testing (user without role)	High	High	**P1**
Script-based READ ACL	High	Medium	**P1**
Administrator access check	High	High	**P2**
Minimum roles per user (least privilege)	High	Medium	**P2**
Check ECE and CSE records	Medium	High	**P2**
Permission matrix and test log	Medium	High	**P3**

P1 = do first, P2 = do next, P3 = support activity.

Selected Concept

Layered ACL protection: the READ ACL combines the Branch = EEE condition with an advanced script that allows administrators and bb1 users. CREATE, WRITE and DELETE are handled by separate ACLs for bb2, bb3 and bb4. The whole setup is then checked by impersonating different users, including one with no role, and by confirming full administrator access.

Reference: https://www.mural.co/templates/brainstorm-and-idea-prioritization